

SIMATS ENGINEERING
CO3 ASSESSMENT TOOL 2(MEDIUM)

COURSE NAME: Ethical Hacking

COURSE CODE: ITA14

COURSE OUTCOME COVERED

CO3: Analyze network services using port scanning, ping sweeps, and enumeration techniques across different operating systems to identify vulnerabilities. (BT4)

Assessment Tool Weightage: 30%

Duration: 90 min

Total Marks: 50

Code of Conduct:

*I **SHAIK ASHA (192473025)** certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.*

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

Port Scanning Challenge

1, Using Nmap, perform a security assessment on the server 192.168.1.20. Identify all open ports and running services. Analyze the purpose of each discovered service and recommend security measures to reduce the attack surface of the system.

Aim

To perform a security assessment of the server 192.168.1.20 using Nmap, identify open ports and running services, analyze their purpose, and recommend security measures to reduce the system's attack surface.

Tool Used

Nmap (Network Mapper)

Commands Used

nmap 192.168.1.20

To identify services and their versions:

nmap -sV 192.168.1.20

For a more comprehensive assessment:

sudo nmap -sS -sV -O 192.168.1.20

Port and Service Analysis

The Nmap scan identifies ports in states such as open, closed, or filtered. An open port indicates that an application or service is listening for network connections.

Port	Common Service	Purpose	Security Concern
21	FTP	File transfer	Unencrypted communication and weak authentication
22	SSH	Secure remote administration	Can be targeted if authentication is weak
23	Telnet	Remote administration	Credentials can be transmitted without encryption
25	SMTP	Email transmission	Misconfiguration may expose information
53	DNS	Domain-name resolution	Misconfiguration can disclose network information

80	HTTP	Web service	Web applications and server vulnerabilities
443	HTTPS	Secure web service	Requires proper TLS and application security
445	SMB	File and printer sharing	Can expose shared resources and increase attack surface
3389	RDP	Windows remote desktop	Can be targeted for unauthorized remote access

Security Analysis

Every open port represents a potential attack surface. If a service is not required for the server's intended purpose, it should be disabled. Services that are required should be restricted using firewall rules and strong authentication.

Service-version detection can also reveal outdated software. Attackers can use this information to identify technologies and compare versions against publicly known vulnerabilities.

Recommendations

1. Disable unnecessary services.
2. Restrict access to administrative services using firewall rules.
3. Replace Telnet with SSH.
4. Keep all services and operating-system components updated.
5. Use strong authentication.
6. Restrict SMB to trusted systems.
7. Disable anonymous or unnecessary access.
8. Monitor network connections and authentication attempts.
9. Use network segmentation where appropriate.
10. Perform periodic vulnerability assessments.

Conclusion

Nmap provides valuable information about the network exposure of 192.168.1.20. Reducing unnecessary open ports and restricting required services can significantly decrease the system's attack surface.

2. Using Nikto, assess the web server hosted on 192.168.1.30. Identify potential web server misconfigurations, outdated components, or exposed files and directories. Discuss the security risks associated with your findings and suggest appropriate mitigation strategies.

Aim

To assess the web server at 192.168.1.30 using Nikto and identify potential misconfigurations, outdated components, exposed files, directories, and other security issues.

Tool Used

Nikto

Nikto is a web-server scanner that checks for common configuration problems, potentially dangerous files, outdated server components, and other known issues.

Commands Used

For HTTP:

```
nikto -h http://192.168.1.30
```

If HTTPS is being used:

```
nikto -h https://192.168.1.30
```

Assessment Areas

Nikto can identify issues such as:

- Outdated web-server software.
- Missing or insecure HTTP security headers.
- Default files.
- Backup files.
- Exposed directories.
- Directory listing.
- Potentially dangerous files.
- Information-disclosure issues.
- Server configuration weaknesses.

Findings Analysis

The actual Nikto output should be examined for each reported finding.

Finding	Possible Risk	Security Impact
Outdated server software	High	Known vulnerabilities may exist
Directory listing	Medium	May expose sensitive files
Backup/configuration files	High	Could disclose credentials or configuration
Missing security headers	Medium	May increase browser-based attack risks
Default files	Low–Medium	Provides unnecessary information
Server information disclosure	Low–Medium	Helps reconnaissance

Security Risks

An attacker could use exposed directories and files to learn about the web application's structure. Backup or configuration files can be particularly sensitive because they may contain credentials, database information, or internal configuration details.

Outdated components can also contain publicly documented vulnerabilities.

Mitigation Strategies

1. Keep the web server and application components updated.
2. Remove unnecessary default and backup files.
3. Disable directory listing.
4. Remove sensitive files from web-accessible directories.
5. Configure appropriate HTTP security headers.
6. Use HTTPS for sensitive communication.
7. Restrict access to administrative directories.
8. Apply secure file and directory permissions.
9. Monitor web-server logs.
10. Perform regular vulnerability assessments.

Conclusion

Nikto helps identify common web-server weaknesses and configuration problems. Addressing outdated components, exposed files, directory listings, and information-disclosure issues can reduce the web server's attack surface.

3. Using Netcat (nc), investigate the host 192.168.1.40 by connecting to open ports and collecting available service banners. Analyze the information obtained and explain how attackers could use banner information during the reconnaissance phase of an attack.

Aim

To use Netcat to connect to open ports on 192.168.1.40, collect available service banners, and analyze how the information can assist reconnaissance.

Tool Used

Netcat (nc)

Netcat is a network utility that can establish TCP or UDP connections and is useful for authorized service testing and banner collection.

Commands Used

First, identify open ports using an authorized port scan. Then connect to individual services:

```
nc -v 192.168.1.40 22
```

For an HTTP service:

```
nc -v 192.168.1.40 80
```

An HTTP request can be sent manually:

```
HEAD / HTTP/1.0
```

The same approach can be applied to other authorized open ports.

Banner Information

A service banner may reveal:

- Service name.
- Software name.
- Software version.
- Operating-system information.
- Protocol information.
- Server configuration details.

For example, an SSH service might return information identifying the SSH implementation and version.

Analysis

Banner information is valuable during reconnaissance because it provides an attacker with information about the technologies running on the target.

An attacker could use the information to:

1. Identify the type of service.
2. Determine the software version.
3. Search vulnerability databases for that version.
4. Identify potentially outdated software.
5. Select appropriate vulnerability-testing techniques.
6. Build a more accurate profile of the target.

Banner information does not automatically mean that the service is vulnerable. It is primarily useful as reconnaissance information.

Security Risks

Excessive banner disclosure can make technology identification easier. If an old version is explicitly disclosed, an attacker can quickly determine which security advisories may be relevant.

Recommendations

1. Keep services updated.
2. Avoid unnecessary version disclosure where practical.
3. Disable unnecessary services.
4. Restrict administrative services.
5. Use firewalls to control access.
6. Monitor suspicious connection attempts.
7. Apply strong authentication.
8. Regularly review exposed services.

Conclusion

Netcat demonstrates how service banners can reveal useful information about network services. Limiting unnecessary information disclosure and keeping services updated can make reconnaissance more difficult and reduce security risks.

4. Using Telnet, examine the server 192.168.1.50 to determine whether remote administration services are accessible. Identify any security concerns related to the discovered services and recommend more secure alternatives where appropriate.

Aim

To examine the server 192.168.1.50 using Telnet and determine whether remote administration services are accessible, identify security concerns, and recommend secure alternatives.

Tool Used

Telnet

Commands Used

To test an authorized TCP service:

```
telnet 192.168.1.50 23
```

For another known service port:

```
telnet 192.168.1.50 22
```

The connection response can indicate whether the selected port is accepting TCP connections.

Analysis

If Telnet is accessible on port 23, it indicates that the server may be providing Telnet-based remote administration.

Telnet is considered insecure for administrative access because it does not provide adequate encryption. Authentication credentials and other session information can potentially be exposed to someone capable of monitoring the network traffic.

Security Concerns

Issue	Risk
Telnet enabled	High
Unencrypted communication	High
Password exposure	High
Remote administration exposed	Medium–High
Weak authentication	High

Secure Alternatives

SSH should be used instead of Telnet for Linux and Unix remote administration.

SSH provides encrypted communication and supports stronger authentication mechanisms.

Recommended controls include:

- Disable Telnet.
- Enable SSH where remote administration is required.
- Use SSH keys where appropriate.
- Disable unnecessary password authentication.
- Restrict SSH to trusted management networks.
- Use strong passwords.
- Implement multi-factor authentication where supported.
- Monitor authentication logs.

Conclusion

Telnet-based administration creates unnecessary security risks because communication is not adequately protected. Replacing Telnet with SSH and restricting remote administration to authorized networks provides a significantly more secure approach.

5. Using Netdiscover, perform host discovery on the network segment 192.168.1.1–50. Identify active hosts on the network and analyze how the discovered information could assist an attacker in planning further enumeration or exploitation activities.

Aim

To perform host discovery on the network segment 192.168.1.1–50 using Netdiscover, identify active hosts, and analyze how the information can assist further authorized security assessment.

Tool Used

Netdiscover

Netdiscover is a network-discovery tool that uses ARP requests to identify active hosts on a local network.

Command Used

```
sudo netdiscover -r 192.168.1.0/24
```

To focus on the specified range, the resulting hosts in the 192.168.1.1 through 192.168.1.50 range should be recorded.

Analysis

Host discovery provides a basic map of the local network. It can identify which IP addresses are currently associated with active devices.

The information may reveal:

- Number of active devices.
- IP addresses of devices.
- MAC addresses.
- Hardware manufacturers.
- Potential network infrastructure devices.
- Possible servers and workstations.

How Attackers Could Use the Information

During unauthorized reconnaissance, an attacker could use discovered hosts to build a map of the network and identify potential targets for further enumeration.

For example, identifying a device manufacturer may provide clues about the type of device. The IP address can then be used by an authorized security tester to determine which services are exposed.

Host discovery therefore provides an important foundation for subsequent security assessment.

Security Risks

Network discovery itself does not compromise a system, but it provides useful information about the network topology.

If an attacker gains access to the local network, host discovery can help them understand the environment and identify systems that may warrant further investigation.

Security Recommendations

1. Use network segmentation.
2. Restrict unauthorized access to internal networks.
3. Use strong Wi-Fi and network authentication.
4. Monitor unusual ARP activity.
5. Maintain network access-control policies.
6. Isolate critical servers and infrastructure.
7. Use firewalls between network segments.
8. Regularly review active network devices.
9. Remove unauthorized devices.
10. Maintain an updated network inventory.

Conclusion

Netdiscover provides an effective method for identifying active devices on a local network. The resulting IP, MAC, and vendor information can help administrators maintain an accurate network inventory and identify unauthorized devices. Network segmentation, access controls, monitoring, and regular network audits can reduce the risks associated with unauthorized network reconnaissance.